정보보안기사 실기 27회 — 문제와 답안

원본: newbt.kr 복원 기출 (1.pdf). 답안은 복원 문항 기준의 모범 답안이며 공식 정답이 아니다.

단답형

1. 접근통제 정책에 대하여 다음 물음에 답하시오.

(A) : 사용자나 사용자 그룹에 근거한 사용자 중심의 접근 제어 수행
(B) : 모든 객체는 정보의 비밀수준에 근거하여 보안 레벨이 주어지고 허가된 사용자만 접근 가능토록 제어
(C) : 사용자와 객체 상호관계를 역할에 따라 접근 제어 수행

답안

A DAC(임의적 접근통제) · **B** MAC(강제적 접근통제) · **C** RBAC(역할 기반 접근통제)

2. MAC 주소(물리 주소)를 기반으로 IP 주소(논리 주소)를 할당받기 위해 사용되며, 디스크 없는 장치나 네트워크 부팅을 지원하는 장비에서 사용하는 TCP/IP 프로토콜은 무엇인가?

답안

RARP(Reverse Address Resolution Protocol)

3. VLAN 구성 방식에 대하여 다음 ( )에 들어갈 명칭을 기술하시오.

(A) 기반 VLAN : 스위치 포트를 각 VLAN에 할당. 같은 VLAN에 속한 호스트 간에만 통신 가능. 가장 일반적인 방식
(B) 기반 VLAN : 호스트의 MAC주소를 VLAN에 등록. 모든 MAC을 등록하고 관리하는 어려움.
(C) 기반 VLAN : 네트워크 주소별로 VLAN 구성.
(D) 기반 VLAN : 같은 통신 프로토콜을 가진 호스트 간에는 통신가능토록 VLAN 설정

답안

A 포트(Port) · **B** MAC 주소 · **C** 네트워크 주소(IP 주소) · **D** 프로토콜

4. 전자금융거래법 제21조2 제4항에 기술된 다음 각호의 업무를 수행하는 사람을 무엇이라고 하나?

1) 전자금융거래의 안정성 확보 및 이용자 보호를 위한 전략 및 계획의 수립
2) 정보기술부문의 보호
3) 정보기술부문의 보안에 필요한 인력관리 및 예산편성
4) 전자금융거래의 사고 예방 및 조치

답안

정보보호최고책임자(CISO)

5. 리눅스 시스템 로그 파일에 대하여 다음 빈칸에 적절한 파일을 기술하시오.

(A) : 현재 시스템에 로그인한 사용자의 상태가 출력되는 로그
(B) : 사용자의 로그인, 로그아웃, 시스템 재부팅 정보가 누적되어 출력되는 로그
(C) : 마지막으로 성공한 로그인 정보가 출력되는 로그

답안

A utmp · **B** wtmp · **C** lastlog

각각 who·w, last, lastlog 명령으로 확인한다.

6. 다음 스캔 방법 중 포트가 닫혀있을 때만 응답이 오는 스캔 방식을 고르시오.

[보기]
SYN scan / FIN scan / XMAS scan / Null scan / Decoy scan

답안

FIN scan, XMAS scan, Null scan

닫힌 포트는 RST를 돌려주고 열린 포트는 응답하지 않는다. SYN scan은 열린 포트에도 SYN/ACK로 응답한다.

7. SW 개발 보안과 관련하여 ( )에 들어갈 취약점명(공격기법)을 기술하시오.

(A) : DB와 연결되어 있는 애플리케이션의 입력값을 조작하여 의도하지 않은 결과를 반환하도록 하는 공격 기법
(B) : 게시판, 웹, 메일 등에 삽입된 악의적인 스크립트에 의해 쿠키 및 기타 개인정보를 특정 사이트로 전송시키는 공격 기법
(C) : 적절한 검증 절차를 수행하지 않은 사용자 입력값이 운영체제 명령어의 일부로 전달되어 의도하지 않은 시스템 명령어가 실행되도록 하는 공격 기법

답안

A SQL 삽입(SQL Injection) · **B** 크로스사이트 스크립트(XSS) · **C** 운영체제 명령어 삽입(OS Command Injection)

8. 다음은 특정 명령어를 수행한 결과이다. ( )에 들어갈 명령어를 기술하시오.

```
root@kali:~#Telnet webserver.com 80
Trying 192.168.1.2…
Connect to webserver.com.
Escape character is '^]'.
( ) * HTTP/1.0

HTTP/1.1 200 OK
Date: Sat, 6 Aug 2022 09:01:01 KST
Server: Microsoft-IIS/5.0
Allow: GET,HEAD,POST,OPTIONS,TRACE
Content-Length:0
Connection: close
Content-Type: text/plain; charset-euc-kr
Connection closed by foreign host.
```

답안

OPTIONS

응답의 Allow 헤더가 서버가 허용하는 메서드 목록이다.

9. 소프트웨어 패치의 종류와 관련하여 ( )에 들어갈 용어를 기술하시오.

(A) : 즉시 교정되어야만 하는 주요한 취약점을 패치하기 위해 배포되는 프로그램으로 서비스팩이 발표된 이후 패치가 추가될 필요가 있을 때 별도로 발표됨.
(B) : 문제를 예방 또는 해결하거나 컴퓨터 작동 방식을 향상시키거나, 컴퓨터 경험을 향상시킬 수 있도록 추가되는 소프트웨어

답안

A 핫픽스(Hotfix) · **B** 업데이트(Update)

10. 매니저와 에이전트 구조로 되어 있고, 네트워크 장비의 상태를 모니터링하고 관리하기 위해 사용되는 TCP/IP 기반 네트워크 프로토콜을 무엇이라고 하나?

답안

SNMP(Simple Network Management Protocol)

11. 어떠한 대책을 도입하더라도 위험을 완전히 제거할 수 없으므로 일정 수준 이하의 위험은 받아들이고 사업을 진행하는 위험대응 방식을 무엇이라고 하나?

답안

위험 수용(Risk Acceptance)

12. 네트워크 논리 그룹을 구분하여 보안을 강화하고, 브로드캐스트 도메인의 범위를 줄여 네트워크 성능 향상을 지원하는 LAN 기술을 무엇이라고 하나?

답안

VLAN(Virtual LAN)

서술형

13. 위험분석 접근법 중 복합접근법의 개념, 장점, 단점을 설명하시오.

답안

개념: 먼저 고위험 영역을 식별해 그 영역에는 상세 위험분석을, 나머지 영역에는 베이스라인(기준선) 접근법을 적용하는 방식이다.
장점: 비용과 자원을 고위험 영역에 집중하므로 효율적이다. 고위험 시스템을 빠르게 식별하고 대응할 수 있다.
단점: 고위험 영역을 잘못 식별하면 위험이 누락되거나 불필요한 비용이 든다.

14. 정보보호조치에 관한 지침은 정보통신망법 제45조 2항에 따라 정보통신서비스 제공자가 정보통신서비스를 제공하는데 사용되는 정보통신망의 안정성 및 정보의 신뢰성을 확보하기 위한 보호조치의 구체적인 내용에 대하여 정하는 것을 목적으로 한다. 해당 지침에서 규정하고 있는 보호조치의 구체적 내용 중 다음 항목에서 규정하고 있는 내용을 기술하시오.

1) 1.2.1.정보보호 방침의 수립 및 이행
2) 1.2.2.정보보호 실행 계획의 수립 및 이행

답안

1) 정보보호 방침: 정보보호의 목표·범위·책임 등을 담은 정보보호 방침을 문서로 수립하고, 경영진(정보보호최고책임자)의 승인을 받아 임직원에게 알리고 이행한다. 방침은 정기적으로 검토해 갱신한다.
2) 정보보호 실행 계획: 정보보호 방침에 따라 조직·인력·예산과 세부 보호조치를 담은 실행 계획을 수립하고, 경영진 승인 후 이행한다. 이행 결과를 정기적으로 점검해 경영진에게 보고한다.

15. 유닉스 시스템에 저장된 파일에 다음과 같은 권한이 설정되었다. 권한의 상세한 의미를 설명하시오.

[설정된 권한]
-rwxr-x--x

답안

8진수로 `751` 이다.
- : 일반 파일
rwx : 소유자는 읽기·쓰기·실행 가능
r-x : 소유 그룹은 읽기·실행 가능, 쓰기 불가
--x : 그 외 사용자는 실행만 가능, 읽기·쓰기 불가
기타 사용자는 바이너리는 실행할 수 있지만 내용은 읽을 수 없다. 셸 스크립트는 읽기 권한이 있어야 실행되므로 기타 사용자는 실행할 수 없다.

16. 재해복구시스템 유형에는 미러사이트, 핫사이트, 웜사이트, 콜드사이트가 있다. 다음 물음에 답하시오.

1) 미러 사이트의 정의
2) 미러 사이트의 장단점 각 2개씩 설명
3) RTO가 가장 오래 걸리는 방식은 무엇이며, 이유는 무엇인가?

답안

1) 정의: 주 센터와 같은 수준의 IT 자원을 원격지에 구축하고, 두 센터가 실시간으로 동시에 서비스하는(Active-Active) 방식이다.

2) 장점: 재해 시 즉시 전환되어 RTO가 0에 가깝다. 실시간 동기화로 데이터 손실(RPO)이 거의 없다.

단점: 구축과 유지 비용이 가장 높다. 데이터 갱신이 잦은 시스템은 실시간 동기화 부하가 커서 적용이 어렵다.

3) 콜드 사이트: 장소와 전원·통신 같은 기본 설비만 갖춰 두고, 장비와 데이터는 재해가 난 뒤에 들여와 구축하므로 복구에 수 주에서 수 개월이 걸린다.

실무형

17. 다음 자바 프로그램은 SQL Injection 에 취약한 소스와 취약점을 해소한 소스코드 이다. ( )에 들어갈 코드를 작성하시오.

[취약한 소스코드]

```
1: // 외부로부터 입력받은 값을 검증 없이 사용할 경우 안전하지 않다.
2: String gubun = request.getParameter("gubun");
3: ......
4: String sql = "SELECT * FROM board WHERE b_gubun = '" + gubun + "'";
5: Connection con = db.getConnection();
6: Statement stmt = con.createStatement();
7: // 외부로부터 입력받은 값이 검증 또는 처리 없이 쿼리로 수행되어 안전하지 않다.
8: ResultSet rs = stmt.executeQuery(sql);
```

[취약점을 해소한 소스코드]

```
1: String gubun = request.getParameter("gubun");
2: ......
3: // 1. 사용자에 의해 외부로부터 입력받은 값은 안전하지 않을 수 있으므로,
   //    PreparedStatement 사용을 위해 ?문자로 바인딩 변수를 사용한다.
4: String sql = "SELECT * FROM board WHERE b_gubun = ( A )";
5: Connection con = db.getConnection();
6: // 2. PreparedStatement 사용한다.
7: PreparedStatement pstmt = con.( B )(sql);
8: // 3. PreparedStatement 객체를 상수 스트링으로 생성하고, 파라미터 부분을
   //    setString등의 메소드로 설정하여 안전하다.
9: pstmt.( C )(1, gubun);
10: ResultSet rs = pstmt.( D );
```

답안

A `?` · B `prepareStatement` · C `setString` · D `executeQuery()`

18. NTP 서비스 취약점을 이용한 DDoS 공격 대응방안 4가지를 서술하시오.

답안

1. NTP 서버를 monlist 명령이 제거된 버전(`4.2.7p26` 이상)으로 업그레이드한다.
2. 업그레이드가 어려우면 `ntp.conf`에 `disable monitor`를 넣어 monlist 기능을 끈다.
3. `restrict default noquery` 등으로 외부에서의 상태 질의를 막고, 허용한 호스트만 질의하게 한다.
4. 방화벽·라우터에서 UDP `123`번 포트의 비정상적인 대량 응답 트래픽을 차단하거나 대역폭을 제한한다. 필요 없는 NTP 서비스는 중지한다.

monlist 요청은 작은 질의로 최근 접속 호스트 최대 600개 목록을 돌려줘 증폭 공격에 악용된다.